

Zero Trust Assignment 2: Case Study 05

ITMS 475/575 – Zero Trust Architecture: Design & Implementation

Illinois Institute of Technology

Fall 2025

Table of Contents

Organization Profile	3
Business Drivers	3
Requests	4
Remote Engineer Accessing CAD Files.....	4
User/System Details	4
Resource/Asset Details	4
Context Factors	4
Current Pain Points	4
Compliance	5
Adversarial Threat Context	5
Security Mechanisms.....	5
Communication & Data Handling.....	5
User Experience.....	5
Supplier Uploading Specifications.....	5
User/System Details	5
Resource/Asset Details	6
Context Factors	6
Current Pain Points	6
Compliance	6
Adversarial Threat Context	6
Security Mechanisms.....	6
Communication & Data Handling.....	7
User Experience.....	7
IoT Sensor on Factory Floor	7
User/System Details	7
Resource/Asset Details	7
Context Factors	7
Current Pain Points	8
Compliance	8
Adversarial Threat Context	8
Security Mechanisms.....	8
Communication & Data Handling.....	8
User Experience.....	8
HR Employee Accessing Personnel Data.....	9
User/System Details	9
Resource/Asset Details	9
Context Factors	9
Current Pain Points	9
Compliance	9
Adversarial Threat Context	9
Security Mechanisms.....	10
Communication & Data Handling.....	10
User Experience.....	10
Research Team Uploading Models.....	10
User/System Details	10
Resource/Asset Details	10
Context Factors	10

Current Pain Points	11
Compliance	11
Adversarial Threat Context	11
Security Mechanisms.....	11
Communication & Data Handling.....	11
User Experience.....	11
Narrative Request.....	11
Summary Table	13
References.....	15

Organization Profile

Organization Name: GaruDyne Aeronautics

Industry Sector: Aerospace Engineering & Defense

Overview:

GaruDyne Aeronautics is a global manufacturer of commercial and military aircrafts, drones, and general aviation systems. GaruDyne operates out of North-America, Europe, and Asia, making it a multi-national player in the Aerospace industry. GaruDyne has over 60,000 employees and 10,000 contractors, making this a large company. To facilitate this size and complexity of operations, GaruDyne has a similarly complex information technology (IT) environment. This IT environment consists of:

- On-prem systems primarily for facilitating CAD design, manufacturing execution systems (MES), and operational technology (OT) devices within factories.
- Cloud systems primarily for facilitating collaboration in corporate environment. This includes product lifecycle management, human resource (HR) management tools, supplier portals, and the normal cloud software as a service (SaaS) like google drive.
- Vendor relationships also are a big part of the GaruDyne IT environment, as we use their tools and portals regularly.

Current Security Posture Maturity:

GaruDyne is currently operating off of the traditional perimeter-based model. However, with recent events where our competitors in the Aerospace Engineering & Defense industry are being targeted, we feel the need to improve our posture. As such, we have begun adopting some zero-trust mechanisms in some of our engineering systems. So while adoption of zero-trust is still in the early stages, we are looking to enhance our security posture maturity further.

Business Drivers

Our desire to adopt zero-trust was based on the following factors:

- Protecting our intellectual property – Many nation states see our industry as a particularly lucrative one in terms of military secrets so we need to protect ourselves and our clients.
- Regulatory Compliance – Considering how much work we do with different countries, we must be compliant with all of their requirements, which are generally very strict and require significant work to maintain.
- Supply Chain Risk – We rely on our contractors and vendors to help us procure the materials we use. However, since we have such a broad supply chain, this means our attack surface is great in this respect.
- Operational Continuity – We need to minimize downtime due to cybersecurity events, as even brief downtime can cause large financial losses.
- Global Collaboration – Our engineers need to be able to collaborate across borders and even continents, all while maintaining compliance.

Requests

As we continue to further improve our security posture by implementing zero-trust, we need to prioritize which parts of our business we implement with zero-trust first and which parts can wait. In accordance with this, below are our top 5 requests that we have right now.

Remote Engineer Accessing CAD Files

User/System Details

- **Who is making request:** Our senior engineers who work remotely.
- **Attributes:**
 - **Role:** Senior Engineers
 - **Department:** Engineering
 - **Privilege Level:** Confidential
 - **Device Details:** Using managed work laptop
- **Risk Factors:**
 - Remote access from potentially arbitrary time and location.
 - Security of physical location
 - Security of network

Resource/Asset Details

- **Resource Being Requested:** Remote Access to system with CAD software and sensitive information.
- **Sensitivity:** Confidential
- **Business Impact:** If compromised, losing this data could cost the business loss of reputation with clientele, as they require us to keep their data secure. Likewise, there would also be large fines for regulation violations.

Context Factors

- **Time of Request:** Local time should be between 8:00 AM and 9:00 PM.
- **Geolocation:** Could be anywhere in the world.
- **Business Event Triggering Request:** Engineer needs to work on CAD design while traveling.

Current Pain Points

- VPN access is very broad, allowing access to entire internal network.
- There is currently no continuous verification
- Geolocation is not considered as part of whether to grant access or not.

Compliance

- International Traffic in Arms Regulation (ITAR) – Requires that there are strict access controls to technical data and defense articles (U.S. Department of State). This is a U.S. Regulation.
- Cybersecurity Maturity Model Certification (CMMC) – Another U.S. regulation requiring that DoD contractors protect sensitive information by implementing a three-tiered model compliant with NIST SP 800-171 (U.S. Department of War).
- The European Union Agency for Cybersecurity (ENISA) has a set of guidelines on implementing Cybersecurity for your organization (Moulinos, K., & Theocharidou, M.). These guidelines are baselines that many companies and nations in the EU require before doing business.

Adversarial Threat Context

- Nation-states are a large concern for GaruDyne
- Insider threats are a concern for GaruDyne

Security Mechanisms

- **Authentication:** Using MFA and SSO
- **Authorization:** Using ABAC
- **Device Trust Checks:**
 - Regular patching
 - Posture assessment
 - Antivirus

Communication & Data Handling

- **Protocols Used:** HTTPS, RDP
- **Encryption Requirements:** encrypted at rest and in transit
- **Logging:** Currently doesn't generate an alert within our SIEM when something sufficiently suspicious occurs.

User Experience

- **Acceptable Friction:** Engineers deal with enough friction trying to work with CAD so trying to ease their friction in other parts is of the utmost priority.

Supplier Uploading Specifications

User/System Details

- **Who is making request:** Manufacturers who have need to upload specifications
- **Attributes:**
 - **Role:** Contractor

- **Department:** Manufacturing
- **Privilege Level:** Regulated
- **Device Details:** Uploading device is not managed by GaruDyne. Server being uploaded to is managed by GaruDyne.
- **Risk Factors:**
 - Uploading files to server
 - Portal needs to be accessible by contractors and vendors

Resource/Asset Details

- **Resource Being Requested:** Access to web portal for uploading files
- **Sensitivity:** Internal/Confidential
- **Business Impact:** If files being uploaded are lost, could result in a loss of reputation, and depending on sensitivity of the specific files lost, could result in large fines.

Context Factors

- **Time of Request:** Generally only done during local business hours (8AM – 9PM) with very rare exceptions.
- **Geolocation:** Our manufacturers are primarily located in the United States, Germany, and China.
- **Business Event Triggering Request:** Supplier accesses portal for specifications.

Current Pain Points

- Currently only have password based authentication for the portal
- Extremely limited view into supplier identity

Compliance

- The CMMC mandates that logs are auditable when it comes to third-party access (U.S. Department of War).

Adversarial Threat Context

- Nation-states are a concern to GaruDyne
- Ransomware is a concern to GaruDyne
- Careless vendors are a concern to GaruDyne

Security Mechanisms

- **Authentication:** Portal is exclusively password based
- **Authorization:** Once user has entered password, they have a blanket authorization to upload the correct file type to the file server. There is not granular control over which supplier can do what within the portal.
- **Device Trust Checks:**

- Regular patching of server
- Posture assessment
- Files are scanned with ClamAV when they are uploaded.

Communication & Data Handling

- **Protocols Used:** HTTPS
- **Encryption Requirements:** Encrypted in transit and at rest.
- **Logging:** Currently unable to access data on who uploaded what, whether the file was deemed malicious or not, and determine whether a user is attempting to do something they are unauthorized from doing.

User Experience

- **Acceptable Friction:** Suppliers access this web portal with moderate frequency and when they do, it is usually a brief visit to upload their files and then immediately leave. Because of this, a fair amount of friction is permissible.

IoT Sensor on Factory Floor

User/System Details

- **Who is making request:** Production floor manager
- **Attributes:**
 - **Role:** Engineer/Supervisor
 - **Department:** Manufacturing
 - **Privilege Level:** Internal Use
 - **Device Details:** OT sensor is currently unmanaged.
- **Risk Factors:**
 - Someone gets onto the IoT network and can see sensor data
 - OT sensors do not get patched regularly

Resource/Asset Details

- **Resource Being Requested:** MES dashboards and production data
- **Sensitivity:** Internal Use
- **Business Impact:** If this data is leaked, there will be a loss of reputation for GaruDyne. Additionally, a dedicated threat actor may be able to get an idea of what we are producing based on patterns in the OT sensor data.

Context Factors

- **Time of Request:** 8:00 AM – 6:00 PM local time.
- **Geolocation:** Our manufacturing plants are located in the United States, China, and Germany

- **Business Event Triggering Request:** The production floor manager wants to view information on the floor to ensure everything is running smoothly and there are no problems within the production line.

Current Pain Points

- Updating our OT devices is a difficult process, and a bad patch could stop production for some time.
- OT sensors are not encrypted
- OT devices are generally not segmented from normal network

Compliance

- The FAA Requires that GaruDyne hold a “Production Certificate” which requires tamper-proof production records (Federal Aviation Administration).

Adversarial Threat Context

- GaruDyne is concerned about nation-state threat actors
- GaruDyne is concerned about insider threats
- GaruDyne is concerned about insecure IoT devices being used as a foothold for a larger attack

Security Mechanisms

- **Authentication:** Accessing the OT sensor data directly requires just a username and password. Accessing the MES dashboard uses MFA and SSO.
- **Authorization:** Authorization when accessing the OT sensor data directly is RBAC. When accessing the MES dashboard authorization is ABAC.
- **Device Trust Checks:**
 - OT Sensors have configuration management controls
 - OT sensors are physically sealed to prevent physical tampering
 - Report to SIEM

Communication & Data Handling

- **Protocols Used:** HTTPS, HTTP
- **Encryption Requirements:** Encrypted in transit and at rest.
- **Logging:** Our OT sensors currently do not report to the SIEM. Our OT devices also currently struggle with auditing specific accounts.

User Experience

- **Acceptable Friction:** If the production floor manager needs to access this data, they should primarily go to the MES dashboard which has MFA and SSO capabilities which is relatively frictionless. However, if for whatever reason they need to access the OT devices directly for this data, it isn't important that they can do so easily. That is to say, a fair amount of friction is permissible for direct access.

HR Employee Accessing Personnel Data

User/System Details

- **Who is making request:** HR Employee
- **Attributes:**
 - **Role:** HR Specialist, HR Relations, Training and Development
 - **Department:** HR
 - **Privilege Level:** Confidential
 - **Device Details:** Using managed work laptop
- **Risk Factors:**
 - Someone not in HR access data accidentally
 - Someone not in HR accessing data intentionally

Resource/Asset Details

- **Resource Being Requested:** Access to employee records within a database
- **Sensitivity:** Confidential
- **Business Impact:** If this employee data is leaked, GaruDyne could face reputational damage as well as fines for violation of regulation.

Context Factors

- **Time of Request:** During local business hours (8:00 PM – 9:00 PM)
- **Geolocation:** Corporate headquarters are in United States, Germany, China, and Spain.
- **Business Event Triggering Request:** An employee in HR requires access to another employee's data.

Current Pain Points

- MFA is currently not globally enforced
- Not all devices are managed

Compliance

- General Data Protection Regulation (GDPR) – The EU requires that PII be regulated and protected. Since employee data is PII, GaruDyne must be compliant with GDPR.
- Sarbanes Oxley (SOX) – SOX requires that things like payroll and accounting be auditable and have strong data integrity (Replicon).

Adversarial Threat Context

- GaruDyne is concerned about insider threats

Security Mechanisms

- **Authentication:** MFA and SSO are enforced for accessing HR Systems
- **Authorization:** Authorization for HR systems is ABAC.
- **Device Trust Checks:**
 - Work Laptops are managed
 - Devices must be connected via VPN to corporate network to access HR systems

Communication & Data Handling

- **Protocols Used:** HTTPS
- **Encryption Requirements:** HR data is encrypted at rest and in transit.
- **Logging:** Any user who accesses or attempts to access HR data is logged.

User Experience

- **Acceptable Friction:** HR personnel frequently need to access HR data as their whole job revolves around it. Because of this, there needs to be minimal friction.

Research Team Uploading Models

User/System Details

- **Who is making request:** Research and Development teams/engineers
- **Attributes:**
 - **Role:** Research and development engineer
 - **Department:** Research and Development
 - **Privilege Level:** Confidential
 - **Device Details:** Using managed laptop and workstation
- **Risk Factors:**
 - Insider Threat leaks R&D to another company or nation-state
 - Employee laptop and data on it is lost

Resource/Asset Details

- **Resource Being Requested:** Access to a cloud with high-performance-computing (HPC) for running simulations and storing models.
- **Sensitivity:** Confidential
- **Business Impact:** If this data is lost GaruDyne may face reputational damage, have to pay fines, and lose their competitive edge.

Context Factors

- **Time of Request:** During local business hours (8:00 AM – 9:00 PM)

- **Geolocation:** R&D Team is solely in the United States
- **Business Event Triggering Request:** R&D Engineer needs to work on and upload a model for their project.

Current Pain Points

- Data classification is inconsistent across different projects.
- Encryption at rest is sporadically enforced. Some workstations currently do not have drive encryption due to being legacy systems.

Compliance

- ITAR (U.S. Department of State) and CMMC (U.S. Department of War) require encryption and access monitoring.

Adversarial Threat Context

- Nation-state actors may want to get information on what other nations are having developed for them by GaruDyne.
- Insider threats may want to get this data to sell to Nation-state actors or competitors.

Security Mechanisms

- **Authentication:** Model uploading portal currently is just password authentication. Cloud HPC should incorporate MFA and SSO.
- **Authorization:** Authorization is ABAC
- **Device Trust Checks:**
 - To access the portal you must connect to corporate network, either via VPN or connecting to the network at a physical location.
 - Both laptops and workstations are managed.

Communication & Data Handling

- **Protocols Used:** HTTPS
- **Encryption Requirements:** Encrypted at rest and in transit.
- **Logging:** Currently unable to tell who uploads what model, who has modified the model, and who ran what simulations.

User Experience

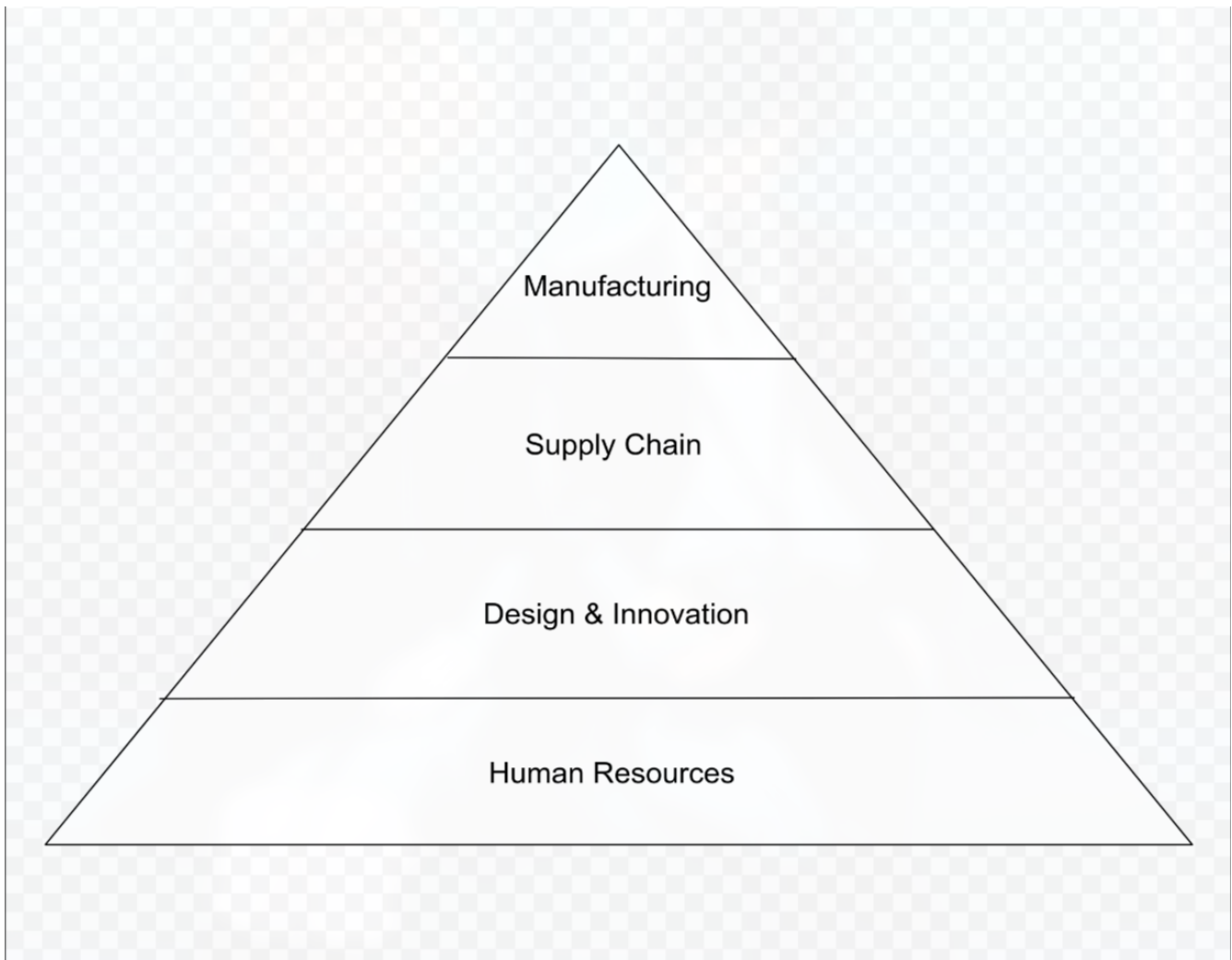
- **Acceptable Friction:** Should be minimal friction. Once the cloud HPC is implemented, most of the work will be done in this location.

Narrative Request

These five requests make up our most important layers of business operation here at GaruDyne.

- Our Engineers design our products and as such, they need to be able to securely do their job from wherever they are.
- Our suppliers are key to manufacturing our products, and ensuring that our suppliers can securely interact with our systems is key to continued success in delivering our supplies to our manufacturing plants.
- When our manufacturing plants receive the materials from our suppliers, it starts the manufacturing process. To facilitate the manufacturing process, we have our sensors so we can improve our processes. However, these sensors need to be secured so that we can maintain our FAA Production Certificate and ensure that our sensors are not tampered with in any capacity.
- At the end of the day though, it is the people who drive our company, and making sure that our HR systems that aid in managing these people are secure is pivotal to maintaining our reputation as a good place to work and we continue to retain talent.
- Innovation is also key to maintaining long term success for GaruDyne as it prevents stagnation. However, if our competitors and/or bad actors get a hold of our confidential designs as we are researching and developing them, we could lose our competitive edge.

With these five requests targeting different, key parts of GaruDyne, we can learn how to implement zero-trust for other systems within each important area using the lessons learned from implementing these requests.



Summary Table

Request #	Request For	Privilege Level	Business Impact	Pain Points
1	Remote Engineer Accessing CAD Files	Confidential	loss of reputation, large fines	Broad VPN access, no continuous verification, geolocation is not considered in trust score.
2	Supplier Uploading Specifications	Regulated	loss of reputation, large fines	Portal only password based, limited view into supplier identity
3	IoT Sensor on Factory Floor	Internal Use	loss of reputation, data leak	Updating OT devices is difficult, OT sensors not encrypted, OT devices not

				segmented
4	HR Employee Accessing Personnel Data	Confidential	loss of reputation, large fines	MFA not globally enforced, not all devices are managed.
5	Research Team Uploading Models	Confidential	loss of reputation, large fines, loss of competitive edge	Inconsistent data classification, encryption is sporadically enforced.

References

- Federal Aviation Administration. (2025, April 3). Production approvals - regulations and policy. Production Approvals - Regulations and Policy | Federal Aviation Administration. https://www.faa.gov/aircraft/air_cert/production_approvals/prod_cert/pc_regs
- Moulinos, K., & Theocharidou, M. (2025). TECHNICAL IMPLEMENTATION GUIDANCE. ENISA. https://www.enisa.europa.eu/sites/default/files/2025-06/ENISA_Technical_implementation_guidance_on_cybersecurity_risk_management_measures_version_1.0.pdf
- Replicon. (2022, October 6). How sarbanes-oxley impacts HR departments | replicon. Deltek. <https://www.replicon.com/blog/how-sarbanes-oxley-impacts-hr-departments/>
- U.S. Department of State. (n.d.). Understand The ITAR. U.S. Department of State. https://www.pmddtc.state.gov/ddtc_public?id=ddtc_public_portal_itar_landing
- U.S. Department of War. (n.d.). About CMMC. CIO. <https://dodcio.defense.gov/cmmc/About/>